

TD N° 6 : Introduction à la sécurité informatique

Exercice 1 :

Une banque en ligne utilise un système permettant aux clients d'effectuer :

- des transferts,
- des paiements,
- la consultation du solde.

L'entreprise subit trois incidents :

1. Pendant 20 minutes, le site ne répond plus.
2. Certains utilisateurs constatent des anomalies dans les montants transférés.
3. Un fichier contenant des données clients a été téléchargé illégalement par un employé.

A faire :

1. Identifiez pour chaque incident quel élément du modèle CIA est compromis.
2. Pour chacun, proposez 2 mesures techniques adaptées.
3. Expliquez l'impact économique et juridique de ces incidents.
4. Classez les incidents du plus grave au moins grave en justifiant.

Exercice 2 :

Un technicien tente de se connecter à distance à un VPN interne. L'administrateur réseau constate dans les logs :

- L'utilisateur s'est authentifié correctement.
- Il a tenté d'accéder à des répertoires auxquels il n'a pas droit.
- Toutes ses actions ont été enregistrées dans un journal d'audit.

1. Identifiez les 3 étapes du modèle AAA illustrées dans ce scénario.
2. Pour chaque étape, expliquez son rôle exact.
3. Quels risques apparaissent si l'une de ces étapes échoue ?
4. Proposez 2 améliorations pour renforcer la sécurité.

Exercice 3 :

Une PME utilise :

- un Wi-Fi non sécurisé,
- des mots de passe simples,
- des mises à jour irrégulières,
- des employés non formés aux attaques par ingénierie sociale.

La direction souhaite une analyse des risques.

1. Identifiez 4 menaces externes et 4 menaces internes.
2. Associez chaque menace à une vulnérabilité correspondante.

3. Évaluez le risque pour chaque couple menace + vulnérabilité en justifiant (faible/moyen/élevé).
4. Proposez un plan de gestion des risques (éviter, atténuer, accepter, transférer).

Exercice 4

Un utilisateur se connecte à un réseau Wi-Fi public. L'attaquant intercepte la connexion et applique une attaque SSL stripping, remplaçant HTTPS par HTTP.

1. Expliquez étape par étape comment se déroule une attaque MITM.
2. Indiquez ce que l'attaquant peut récupérer.
3. Expliquez pourquoi l'attaque SSL Stripping fonctionne.
4. Proposez un schéma textuel montrant le flux des données (Utilisateur → Attaquant → Serveur).
5. Donnez 5 contre-mesures.

Exercice 5

Une entreprise subit une attaque DDoS de type « saturation HTTP ».

- Le serveur peut traiter 10 000 requêtes / seconde.
 - Le trafic légitime représente 2 000 requêtes / seconde.
 - Le botnet génère 180 000 requêtes / seconde.
1. Calculez la surcharge totale du serveur.
 2. Déterminez le pourcentage de trafic malveillant.
 3. Expliquez pourquoi le serveur devient indisponible.
 4. Proposez et justifiez 4 protections efficaces contre ce type d'attaque.

Exercice 6

Une application construit la requête suivante :

<code>SELECT * FROM users WHERE username = 'X' AND password = 'Y';</code>

Un attaquant saisit :

- dans username : ' OR '1'='1
- dans password : abcd

1. Reconstituez la vraie requête SQL exécutée.
2. Montrez pourquoi la condition devient toujours vraie.
3. Expliquez ce que l'attaquant obtient.
4. Proposez 4 méthodes pour corriger la vulnérabilité.
5. Expliquez pourquoi cette attaque est classée comme attaque active.

Exercice 7

On souhaite chiffrer le message (César):

SÉCURITÉ

(ignorer accents → SECURITE)

avec la clé $k = 7$.

1. Convertir chaque lettre en indice ($A=0, \dots, Z=25$).
2. Appliquer la formule :
$$c = (p + k) \bmod 26$$
3. Donner le texte chiffré final.
4. Proposer ensuite le déchiffrement complet pour vérifier.
5. Expliquez pourquoi ce chiffrement est vulnérable.

Exercice 8

On chiffre le message (Vigenère) :

INFORMATION

avec la clé :

SECURITE

1. Répétez la clé sur toute la longueur.
2. Convertissez lettres du message + lettres de clé → indices.
3. Appliquez :

$$C = (P + K) \bmod 26$$

4. Déduisez le texte chiffré final.
5. Expliquez en quoi ce chiffrement est plus robuste que César.
6. Identifiez sa principale faiblesse.